Operation Glass Harbor: Synthetic Intrusion Report

This report describes an invented intrusion against a fictional logistics company. Every name, address and indicator in it was made up for testing the Sherklock Honed pipeline.

Initial Access

The operators researched the victim on professional networking sites and collected the names and email addresses of finance staff. They registered a look-alike domain and set up a mail server a week before the attack.

The intrusion began with spearphishing emails that carried a malicious Excel attachment disguised as an unpaid invoice. A second wave of emails contained a link to a fake document-sharing page that harvested Microsoft 365 passwords.

In parallel, the actors exploited a vulnerability in the company's internet-facing VPN appliance to gain a foothold.

Execution and Persistence

When the victim enabled macros, the macro launched PowerShell with a base64-encoded command. The script downloaded a second-stage loader from a compromised WordPress site and executed it in memory.

The loader used rundll32 to run a malicious DLL and injected code into the explorer.exe process. To survive reboots it created a scheduled task named OneDriveSync that ran every thirty minutes.

It also added a Run key in the registry and installed a new Windows service that pointed to the loader.

On the VPN appliance, the attackers dropped a web shell that allowed them to run commands through HTTP requests.

Defense Evasion

The malware disabled Windows Defender real-time protection and added exclusions for its own folders. The loader binary was packed and its strings were encrypted with a single-byte XOR key.

The operators cleared the Security and System event logs and deleted their tools after use. They also timestomped their files so that they appeared to be part of the original Windows installation.

Credential Access and Discovery

The actors used a renamed copy of Mimikatz to dump credentials from LSASS memory. They also extracted saved passwords from web browsers and performed Kerberoasting against service accounts.

To understand the environment they ran whoami, ipconfig, systeminfo and net group domain admins. They enumerated network shares, listed running processes and scanned the internal network for open RDP and SMB ports.

Lateral Movement

With stolen administrator credentials, the operators moved laterally over RDP to the file server and two domain controllers. They used PsExec and WMI to execute commands on several workstations.

Additional tools were copied between hosts through administrative SMB shares.

Collection and Exfiltration

Files from the finance and HR shares were collected and staged in a temporary folder on the file server. The data was compressed into password-protected RAR archives before it was sent out.

The archives were exfiltrated over HTTPS to a cloud storage account controlled by the attackers. Smaller files were also uploaded to a file-sharing website.

The actors captured screenshots and recorded keystrokes on the CFO's laptop.

Command and Control

The backdoor communicated with its command and control server over HTTPS using a custom user agent. As a fallback it used DNS tunnelling through a dynamic DNS domain.

Traffic was relayed through a chain of compromised home routers to hide the real infrastructure.

Impact

In the final stage the actors deleted volume shadow copies and encrypted files on the file server and backup system. A ransom note demanded payment in Bitcoin and threatened to publish the stolen data.

Several virtual machines were shut down, which stopped the company's shipment tracking service for two days.

Indicators of compromise

44d88612fea8a8f36de82e1278abb02f 185.220.101.4 hxxps://invoice-portal[.]com/load.bin

e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855 10.13.37.21 update-cdn[.]net